WALKER PRESS

CompTIA Security+ SY0-701

Practice Exam 1 of 5

90 Questions | 90 Minutes | Passing score 750 on a scale of 100–900

• This practice exam mirrors the format of the CompTIA Security+ SY0-701 certification exam: a maximum of 90 questions in 90 minutes.
• CompTIA reports the passing score as 750 on a scale of 100 to 900. That scale is CompTIA's own and is not a percentage of correct answers, so this document does not print a pass mark of its own. Use the Answer Key to find the objectives that need another evening.
• Questions are weighted by domain as on the real exam: General Security Concepts 12%, Threats, Vulnerabilities, and Mitigations 22%, Security Architecture 18%, Security Operations 28%, Security Program Management and Oversight 20%.
• Question types include Multiple Choice, Select Two/Three, Matching and Ordering. For Matching questions, pair each item with the best description. For Ordering questions, arrange the items in the correct sequence.
• The Answer Key with a full explanation for every question is at the end of this document.

www.walker-press.com

Questions

Question 1 [Multiple Choice]

Which measure is MOST effective at reducing unintentional insider threats caused by employees falling for social-engineering attacks?

- **A.** Least functionality
- **B.** Enforced password changes
- **C.** Containerization
- **D.** Security awareness training

Question 2 [Multiple Choice]

What is the process of identifying the geographical location of a mobile device?

- **A.** Geomonitoring
- **B.** Geolocation
- **C.** Geotracking
- **D.** GeoID

Question 3 [Multiple Choice]

After a user is initially authenticated, what is a primary benefit of issuing a session token?

- **A.** They enforce disk-level encryption on the endpoint's local storage
- **B.** They eliminate the need for password rotation
- **C.** They allow session management without constant re-authentication
- **D.** They increase the bandwidth available for cloud storage transfers

Question 4 [Multiple Choice]

Fill in the blank: _____ is the practice of removing unnecessary services and software to reduce attack surface.

- **A.** Phishing
- **B.** Social engineering
- **C.** System hardening
- **D.** Buffer overflow

Question 5 [Matching]

Match each NIST Cybersecurity Framework core function to its activity.

Items	Descriptions
1. Identify	**A.** Restrict unauthorized access
2. Protect	**B.** Contain the impact of incidents
3. Detect	**C.** Alert on anomalies
4. Respond	**D.** Inventory critical assets and data

Question 6 [Multiple Choice]

A company needs a wireless connection method for pairing corporate mobile devices with nearby peripherals. Which technology should it use?

A. Ethernet
B. Wi-Fi
C. Bluetooth
D. Cellular

Question 7 [Multiple Choice]

Fill in the blank: The _____ score helps prioritize vulnerabilities based on exploitability and impact.

A. CVE
B. CVSS
C. NIST score
D. CWE

Question 8 [Multiple Choice]

Which type of buffer is automated and has two interlocking doors, only one of which can be opened at a time?

A. Access control vestibule
B. Reception area
C. Waiting room
D. Vestibule office

Question 9 [Multiple Choice]

What is the advantage of XDR over EDR?

A. XDR is faster than EDR.
B. The agent footprint of XDR is significantly smaller than an agent for EDR.
C. XDR collects and correlates data across various network appliances.
D. XDR does not require user input.

Question 10 [Select Two]

An administrator is hardening a newly deployed Linux web server. Which TWO actions are recognized hardening techniques? (Select TWO.)

A. Open Telnet for easier remote access
B. Disable unused ports and protocols
C. Install a duplicate copy of the application
D. Change default vendor passwords
E. Grant all users administrative rights

Question 11 [Matching]

Match each incident response term with its definition.

Items	Descriptions
1. Eradication	**A.** Restore systems to normal operations
2. Containment	**B.** Analyze what went well or failed
3. Recovery	**C.** Limit spread and impact
4. Lessons learned	**D.** Remove the threat from affected systems

Question 12 [Multiple Choice]

Which characteristic of some open-source libraries can increase software supply-chain risk if governance and maintenance are weak?

A. These libraries are not owned and controlled by any single entity
B. They use coding tools that are considered inferior to standardized tools
C. They are "stubs" that cannot be properly verified for malware
D. Their platforms are known to be owned and managed by threat actors

Question 13 [Multiple Choice]

You are configuring a system to ensure that no single employee can approve both invoice creation and payment processing. What security concept are you applying?

A. Least functionality
B. Discretionary access control
C. Separation of duties
D. Role-based access control

Question 14 [Select Two]

A security analyst suspects that several gigabytes were copied from a database server to an external address overnight. No packet capture was running at the time. Which TWO data sources would MOST directly show the destination and volume of the outbound transfer? (Select TWO.)

A. The most recent vulnerability scan report for the database server
B. Firewall logs recording allowed outbound connections with byte counts
C. NetFlow records exported from the core switch
D. The antivirus signature update log on the server
E. The password policy audit report for the database accounts

Question 15 [Multiple Choice]

An authorized vulnerability scan has already been scoped and configured. Which action should be taken immediately before executing the scan to detect the latest known vulnerabilities?

A. Update the plug-ins
B. Execute the scan
C. Set the scope
D. Determine the sensitivity level

Question 16 [Multiple Choice]

Sergio is investigating a suspected compromise and needs to examine the contents of network communications captured during the incident. Which data source would be MOST useful?

A. Data from computer incident monitoring organizations
B. Network packet analysis
C. Law enforcement data
D. Insurance company data

Question 17 [Multiple Choice]

Makena needs an EAP method that creates a server-authenticated TLS tunnel and supports legacy inner authentication protocols such as PAP for passwords or one-time password tokens, without requiring client certificates. Which should she recommend?

A. EAP-TTLS
B. EAP-FAST
C. EAP-TLS
D. EAP-SSL

Question 18 [Matching]

Drag each adversary motivation to the description that best defines it.

Items	Descriptions
1. Espionage	**A.** Spreading false information to mislead the public
2. Service disruption	**B.** Making systems or services unavailable to interrupt operations
3. Blackmail	**C.** Stealing confidential information for strategic or competitive intelligence
4. Financial gain	**D.** Threatening to release stolen data unless demands are met
5. Revenge	**E.** Stealing money, card data, or credentials that can be sold for profit
	F. Retaliating against an employer or individual for a perceived wrong
	G. Disclosing flaws responsibly and within the law

Question 19 [Multiple Choice]

A vendor gains access to internal systems through a trusted connection. What risk does this illustrate?

A. Privilege escalation
B. Insider threat
C. Third-party risk
D. Data classification failure

Question 20 [Multiple Choice]

During the selection of a managed security service provider, the procurement lead who scores the proposals discloses that a close family member is a sales director at one of the three bidding vendors. Which vendor selection concern does this situation represent?

A. A rules-of-engagement violation
B. A lack of due diligence
C. A supply chain dependency
D. A conflict of interest

Question 21 [Multiple Choice]

Which of the following would MOST help detect unauthorized access attempts in real time?

- **A.** Load balancing
- **B.** SIEM with alerting
- **C.** DLP
- **D.** Endpoint encryption

Question 22 [Multiple Choice]

Fill in the blank: _____ ensures that information is accurate and has not been modified in transit or at rest.

- **A.** Availability
- **B.** Confidentiality
- **C.** Non-repudiation
- **D.** Integrity

Question 23 [Matching]

Match each platform type to its attribute.

Items	Descriptions
1. Cloud	**A.** Scalable resource model via internet
2. On-premises	**B.** Provider handles all backend infrastructure
3. Serverless	**C.** Mix of local and internet-hosted infrastructure
4. Hybrid	**D.** Full control of hardware and network

Question 24 [Multiple Choice]

What is the benefit of immutable backups?

- **A.** They require less storage
- **B.** They cannot be altered once written
- **C.** They are compressed in real time
- **D.** They allow live editing by admins

Question 25 [Multiple Choice]

Wolfgang-Cashman is a new intern at the online company WebHighSchoolStore.com. He has been assigned the task of researching all the similar domain names to theirs in order to counteract attacks. What is Wolfgang-Cashman combating?

- **A.** Mistranslations
- **B.** Spimming
- **C.** Typo squatting
- **D.** Redactioning

Question 26 [Multiple Choice]

Eden is creating an incident response plan. Which process involves completing incident documentation, performing detailed analysis to increase security, and improving future response efforts?

- **A.** Tactical summary
- **B.** Mission-essential functions
- **C.** Lessons learned
- **D.** Recovery objectives

Question 27 [Multiple Choice]

Scenario: A company detects that an employee accessed files outside their role. Which type of control would have BEST prevented this?

A. Segmentation
B. Whitelisting
C. Data tokenization
D. Role-based access control

Question 28 [Multiple Choice]

What is data correlation?

A. Finding linkages from multiple data sources.
B. A requirement for using ML.
C. Using a minimum of three external and three internal data sources to understand a zero-day attack.
D. A dated technology no longer used due to the introduction of security information and event management.

Question 29 [Multiple Choice]

Which of the following strategies would MOST reduce the risk of lateral movement in a flat network?

A. Patch management
B. Microsegmentation
C. NAT
D. Host hardening

Question 30 [Multiple Choice]

Nia is writing an email to an employee about a wireless attack that is designed to capture wireless transmissions from legitimate users. Which type of attack is she describing?

A. Evil twin attack
B. Sleeper attack
C. NFC capture attack
D. WPA grab attack

Question 31 [Multiple Choice]

Zendaya is helping her neighbor install and configure a new wireless router. Her neighbor is reluctant to configure the settings on the device but just wants to accept the default settings. Which of these is NOT a reason Zendaya would give regarding the risks of an improperly configured wireless router?

A. Malware can be injected into a computer connected to the WLAN.
B. User names, passwords, credit card numbers, and other information sent over the WLAN could be captured by an attacker.
C. An attacker can steal data from any folder with file sharing enabled.
D. Wireless devices could be susceptible to an INKSPOT attack.

Question 32 [Multiple Choice]

A company configures access to certain documents based on department, time of day, and location. What model is this?

A. ABAC
B. DAC
C. RBAC
D. MAC

Question 33 [Multiple Choice]

Which statement regarding a keylogger is NOT true?

A. Hardware keyloggers are installed between the keyboard connector and computer keyboard USB port.
B. Software keyloggers can be designed to send captured information automatically back to the attacker through the Internet.
C. Software keyloggers are generally easy to detect.
D. Keyloggers can be used to capture passwords, credit card numbers, or personal information.

Question 34 [Multiple Choice]

Which of the following is primarily a spyware distribution method rather than a surveillance or post-installation capability?

A. Tracking software
B. Automatic download of software
C. Active tracking technologies
D. System-modifying software

Question 35 [Multiple Choice]

Which agreement type is generally intended to document a mutual understanding between parties without creating legally binding obligations?

A. MSA
B. SLA
C. MOU
D. BPA

Question 36 [Multiple Choice]

Which of the following would MOST directly prevent users from creating short, easily guessed passwords?

A. Application firewall
B. Biometric authentication
C. Password complexity policies
D. Security training

Question 37 [Multiple Choice]

Alois is explaining to his parents his new position in a SOC. Which of the following would Alois NOT say about a SOC?

A. A SOC responds to cybersecurity incidents.
B. It is responsible for detecting and analyzing cybersecurity incidents.
C. It uses strictly automatic processes.
D. It houses the IT security team.

Question 38 [Matching]

Match each governance term with its description.

Items	Descriptions
1. Policy	**A.** Optional recommended practice
2. Standard	**B.** Mandatory, detailed technical requirement
3. Guideline	**C.** High-level rule for decision-making
4. Procedure	**D.** Step-by-step action plan

Question 39 [Multiple Choice]

Scenario: A company uses AES-256 to protect database backups. Which type of control is this?

A. Technical
B. Compensating
C. Physical
D. Administrative

Question 40 [Matching]

Match each risk term with its meaning.

Items	Descriptions
1. Risk avoidance	**A.** Buying cyber insurance
2. Risk acceptance	**B.** Not launching a project due to potential risk
3. Risk mitigation	**C.** Applying a patch to remove vulnerability
4. Risk transference	**D.** Choosing to do nothing after risk evaluation

Question 41 [Matching]

Match each logging feature to its function.

Items	Descriptions
1. Syslog	**A.** Centralized analysis and storage
2. Immutable logs	**B.** Preserves evidence integrity
3. Log aggregation	**C.** Prevents tampering after capture
4. Chain of custody	**D.** Standardizes format for remote log collection

Question 42 [Matching]

Match each security framework with its area of focus.

Items	Descriptions
1. COBIT	**A.** Information security management systems
2. ISO/IEC 27001	**B.** Baseline technical controls
3. NIST SP 800-53	**C.** Security control catalog for federal systems
4. CIS Controls	**D.** IT governance and process management

Question 43 [Multiple Choice]

Which of the following manipulates the trusting relationship between web servers?

A. SCSI
B. SSRF
C. CSRF
D. EXMAL

Question 44 [Multiple Choice]

Cahill is writing a web application and wants to reduce the risk of XSS by checking untrusted user-supplied data before it is processed. Which coding technique should he use?

A. Code signing
B. Input validation
C. Normalization
D. Obfuscation

Question 45 [Multiple Choice]

What is the main purpose of a tabletop exercise?

A. Perform root cause analysis
B. Conduct red team evaluation
C. Test DLP policies in production
D. Simulate response to a security incident

Question 46 [Multiple Choice]

Fill in the blank: The _____ phase of incident response focuses on isolating affected systems and preventing further damage.

A. Playbook execution
B. Forensic imaging
C. Containment
D. Threat hunting

Question 47 [Multiple Choice]

What is the primary function of hashing in information security?

A. To authenticate user credentials
B. To encrypt data during transmission
C. To verify data integrity
D. To compress large files

Question 48 [Matching]

Match each cryptographic function with its purpose.

Items	Descriptions
1. Hashing	**A.** Ensures integrity with a fixed-length output
2. Symmetric encryption	**B.** Uses a key pair for secure data exchange
3. Asymmetric encryption	**C.** Encrypts using a shared secret key
4. Digital signature	**D.** Provides authentication and non-repudiation

Question 49 [Matching]

Match each incident response phase with its activity.

Items	Descriptions
1. Containment	**A.** Scan for malware and clean systems
2. Identification	**B.** Disconnect affected systems
3. Preparation	**C.** Define roles and responsibilities
4. Eradication	**D.** Analyze logs for signs of compromise

Question 50 [Multiple Choice]

Which attack intercepts communications between a web browser and the underlying OS?

A. MTTR
B. MITM
C. MITB
D. MRTR

Question 51 [Matching]

Match each attack scenario to the threat vector it used.

Items	Descriptions
1. A USB drive labeled 'Payroll' left in the parking lot	**A.** Image-based
2. A malicious macro inside an emailed invoice attachment	**B.** Removable device
3. A driver update pushed from a compromised software vendor	**C.** Open service port
4. A QR code sticker placed over a legitimate payment poster	**D.** Message-based email or file
	E. Supply chain
	F. Default credentials

Question 52 [Multiple Choice]

Fill in the blank: A _____ is a security device placed between internal networks and external connections to filter traffic.

A. Threat hunting
B. Firewall
C. Playbook execution
D. Vulnerability scanning

Question 53 [Multiple Choice]

Fill in the blank: The _____ metric in CVSS reflects how severely a vulnerability impacts confidentiality, integrity, and availability.

A. Gap analysis
B. Zero trust
C. Non-repudiation
D. Base score

Question 54 [Multiple Choice]

Which WPA3 technology mitigates offline password-guessing attacks by replacing pre-shared-key authentication with a password-authenticated key exchange?

A. XR3
B. OWE
C. SAE
D. PMF

Question 55 [Ordering]

Arrange the following steps in a vulnerability management lifecycle.

Place the following in the correct order:

A. Remediation
B. Verification
C. Discovery
D. Assessment

Question 56 [Multiple Choice]

Which of the following BEST describes a man-in-the-middle (MITM) attack?

A. Injecting code into a website
B. Using a fake login page to steal credentials
C. Intercepting communication between two parties
D. Escalating local privileges

Question 57 [Multiple Choice]

What is the primary concern when transferring PII over an unencrypted protocol?

A. Data interception by unauthorized parties
B. Compression errors introduced during transfer
C. Higher CPU load on the sending and receiving hosts
D. Repeated authentication failures at the gateway

Question 58 [Multiple Choice]

Which of the following is NOT an activity associated with vulnerability management?

A. Data retention
B. Responsible disclosure program
C. Vulnerability scanning
D. Penetration testing

Question 59 [Multiple Choice]

A company stores health records for U.S. patients. Which regulation most likely applies?

A. HIPAA
B. GDPR
C. FISMA
D. PCI DSS

Question 60 [Multiple Choice]

What is the main purpose of a business impact analysis (BIA)?

A. Determine regulatory and contractual compliance obligations
B. Plan incident response and escalation procedures
C. Identify critical business functions and dependencies
D. Catalogue third-party vendors and their contract terms

Question 61 [Multiple Choice]

What is one risk of using default credentials in enterprise systems?

A. Frequent account lockouts for legitimate users
B. Loss of the encryption keys held in escrow
C. Authentication fatigue from repeated MFA prompts
D. Unauthorized access from known exploits

Question 62 [Multiple Choice]

What is the primary goal of implementing configuration baselines?

A. To prevent data loss during unplanned system failures
B. To give end users more freedom to change system settings
C. To improve application response times under peak user load
D. To establish secure and standardized system settings

Question 63 [Multiple Choice]

Which term refers to a method that uses multiple layers of security to protect systems?

A. Tokenization
B. Least privilege
C. Social engineering
D. Defense in depth

Question 64 [Multiple Choice]

Which of the following is NOT an advantage of an organization sharing threat intelligence information?

A. Organizations can independently confirm their own observations with other sharing members and improve the overall quality of the threat information through the reduction of ambiguity and errors
B. Organizations can identify third-party OSINT providers more quickly to purchase their threat feeds
C. Organizations can leverage the collective knowledge, experience, and capabilities of other organizations in their sharing community to gain a more complete understanding of the threats they face
D. Organizations can enrich their own existing information and make it more actionable

Question 65 [Multiple Choice]

An organization's leadership is willing to accept higher levels of risk in pursuit of business growth and new opportunities. Which type of risk appetite does this describe?

A. Neutral
B. Expansionary
C. Conservative
D. Restrictive

Question 66 [Multiple Choice]

A SIEM correlation rule for failed logins generates about 400 alerts per day. Analysts have confirmed that more than 90 percent come from one service account whose password was changed but never updated in a scheduled job, and they have started ignoring the whole queue. Which action should the security team take FIRST?

A. Quarantine every host where the service account attempts to log in
B. Disable the failed-login correlation rule until the queue is empty
C. Shorten the log retention period so that fewer events are correlated
D. Tune the rule to exclude the misconfigured service account

Question 67 [Multiple Choice]

Scenario: An attacker convinces a user to install an application disguised as a legitimate tool. What type of threat is this?

A. Rootkit
B. Ransomware
C. Adware
D. Trojan

Question 68 [Multiple Choice]

Which of the following is a primary benefit of asset inventory management in cybersecurity?

A. Speeds up application development
B. Identifies unmanaged or vulnerable devices
C. Reduces insurance premiums
D. Prevents phishing attacks

Question 69 [Multiple Choice]

A company uses endpoint security software to block unauthorized external USB storage devices before they can transfer data. How should this control be classified?

A. Managerial and detective
B. Physical and deterrent
C. Technical and preventive
D. Operational and corrective

Question 70 [Multiple Choice]

Which statement about ransomware is NOT accurate?

A. Once a device is infected with ransomware, it can never function normally again.
B. Ransomware can encrypt data and make resources inaccessible.
C. Ransomware attacks can severely disrupt an organization's operations.
D. Ransomware is often delivered through message-based vectors such as phishing emails.

Question 71 [Ordering]

Arrange the steps to obtain and deploy a digital certificate in the correct order.

Place the following in the correct order:

A. The CA validates the requester's identity
B. Install the certificate on the server
C. Create a certificate signing request containing the public key
D. Generate a public/private key pair
E. The CA issues the signed digital certificate
F. Submit the CSR to the certificate authority

Question 72 [Matching]

Match each attack technique with its target.

Items	Descriptions
1. Brute-force	**A.** LAN devices
2. Cross-site scripting (XSS)	**B.** Email recipients
3. ARP spoofing	**C.** Web browser sessions
4. Phishing	**D.** Authentication systems

Question 73 [Matching]

Match each secure protocol with its purpose.

Items	Descriptions
1. HTTPS	**A.** Encrypt web-based communications
2. SFTP	**B.** Provide encrypted file transfer
3. SNMPv3	**C.** Add confidentiality to legacy apps
4. TLS	**D.** Secure monitoring of network devices

Question 74 [Ordering]

Arrange the events of a Zero Trust access request in the order they occur.

Place the following in the correct order:

A. The policy engine evaluates identity, device posture, and context
B. A subject requests access to a resource
C. The enforcement point grants access and the session is logged
D. The policy enforcement point intercepts the request
E. The policy administrator issues or denies session credentials based on the decision

Question 75 [Multiple Choice]

Which of the following best supports forensic evidence integrity during acquisition?

A. Firewall rule
B. Tokenization
C. EDR alert
D. Write blocker

Question 76 [Multiple Choice]

Which technology is specifically designed to establish behavioral baselines for individual hosts over time and flag outbound connections that deviate from those baselines?

A. IDS
B. SIEM
C. Packet sniffer
D. UEBA

Question 77 [Multiple Choice]

When classifying data for protection, which of the following is a recognized data type?

A. Financial information
B. Strategic
C. Compliance
D. Tactical

Question 78 [Multiple Choice]

Fill in the blank: The _____ defines the acceptable amount of downtime for a system or application.

A. RPO (Recovery Point Objective)
B. RTO (Recovery Time Objective)
C. MTBF (Mean Time Between Failures)
D. MTTR (Mean Time To Repair)

Question 79 [Multiple Choice]

A manager decides not to patch a minor issue because exploitation is unlikely and mitigation is costly. This is an example of:

A. Risk acceptance
B. Risk transfer
C. Risk avoidance
D. Risk mitigation

Question 80 [Multiple Choice]

What is the function of an Acceptable Use Policy (AUP)?

A. To assign risk ratings to information systems
B. To verify endpoint health before network access
C. To outline responsible use of organizational resources
D. To define remote access and VPN client configuration standards

Question 81 [Multiple Choice]

Which log type is most relevant during user account misuse investigation?

A. Authentication log
B. Email delivery log
C. Network flow log
D. DNS query log

Question 82 [Multiple Choice]

What is a publicly accessible centralized directory of digital certificates that can be used to view the status of a digital certificate?

A. CA
B. CR
C. CB
D. CX

Question 83 [Multiple Choice]

Five administrators need domain-level privileges a few times each month for maintenance windows. The CISO wants no standing administrative accounts and requires that any elevated credential be issued only for an approved task and become unusable automatically when the task ends. Which approach BEST meets these requirements?

A. Just-in-time elevation using ephemeral credentials from a PAM vault
B. Permanent membership in the domain administrators group protected by multifactor authentication
C. A shared administrator account protected by a 90-day password expiration policy
D. Role-based access control combined with time-of-day login restrictions

Question 84 [Multiple Choice]

A company is outsourcing log analysis to a third-party provider. Which document should define measurable service requirements, such as analysis response times, availability, and performance targets?

A. MOU
B. SLA
C. NDA
D. AUP

Question 85 [Multiple Choice]

A _____ is a piece of code that lies dormant until triggered by a specific condition or time.

A. Dropper
B. Logic bomb
C. Rootkit
D. Worm

Question 86 [Multiple Choice]

Bob sends Alice a message. Which of the following gives Alice the strongest assurance that this specific message was created and sent by Bob?

A. Digital signature
B. Digital certificate
C. Digest
D. Encrypted signature

Question 87 [Matching]

Match each web attack with its primary goal.

Items	Descriptions
1. SQL injection	**A.** Inject code into a browser session
2. Cross-site scripting	**B.** Extract data from backend databases
3. Directory traversal	**C.** Redirect users into clicking hidden UI elements
4. Clickjacking	**D.** Gain unauthorized access to file system paths

Question 88 [Multiple Choice]

Fill in the blank: The document that lists all known risks and their treatment plans is called a _____.

- **A.** Risk assessment report
- **B.** Risk register
- **C.** Business impact analysis
- **D.** Risk matrix

Question 89 [Multiple Choice]

Fill in the blank: A _____ audit verifies compliance with laws, regulations, and internal controls.

- **A.** Security awareness training
- **B.** Compliance audit
- **C.** Risk assessment
- **D.** Policy review

Question 90 [Ordering]

A company has committed to earning an external certification against an information security standard within a year. The compliance lead decides to run a gap analysis before the certification audit is booked. Arrange the activities in the order they should be performed.

Place the following in the correct order:

- **A.** Undergo the independent third-party audit and receive the certification decision
- **B.** Define the assessment scope and the control objectives the organization must meet
- **C.** Remediate the shortfalls, prioritizing them by risk
- **D.** Identify where current practice falls short of the required controls
- **E.** Review policies, configurations, and interview technical staff to document the current state

Answer Key

Each answer is followed by the reasoning behind it, including why the other options fall short.

Q1: D

D. Security awareness training is correct because it directly reduces the likelihood that employees fall for phishing, pretexting, and similar social-engineering lures, which is the cause of the unintentional insider incidents described. C. Containerization is incorrect because isolating applications or workspaces does not make employees less likely to be deceived. A. Least functionality is incorrect because removing unnecessary software and services hardens systems but does not address human susceptibility to manipulation. B. Enforced password changes are incorrect because periodically rotating passwords does not stop an employee from disclosing credentials or acting on a fraudulent request.

Q2: B

B (Geolocation) is correct: geolocation is the process of identifying the geographical location of a mobile device, typically using GPS, cell tower signals, or Wi-Fi positioning. It is the underlying capability that mobile device management relies on for features such as locating a lost device or applying location-based access rules. C (Geotracking) is incorrect because it is not the Security+ term for determining a device's position; it loosely describes following a device over time, which depends on geolocation but is not the process of identifying the location itself. D (GeoID) is incorrect because it is not a recognized mobile security concept. A (Geomonitoring) is incorrect because it is not a standard term; the objectives use geolocation for determining where a device is and geofencing for acting on that location.

Q3: C

B. Eliminating the need for password rotation is incorrect: issuing session tokens does not change password lifecycle policy, which is managed separately. A. Enforcing disk-level encryption on the endpoint's local storage is incorrect: session tokens operate at the authentication and session layer and have nothing to do with storage encryption, which is provided by full-disk encryption. C. Allowing session management without constant re-authentication is correct: after the initial authentication, the token is presented with subsequent requests, so the user does not have to re-enter credentials for every action during the session. D. Increasing the bandwidth available for cloud storage transfers is incorrect: tokens have no effect on network capacity.

Q4: C

C. System hardening is correct. System hardening reduces a system's attack surface by disabling unnecessary services, closing unused ports, removing default accounts, applying security patches, and enforcing secure configurations. The goal is to limit the number of vectors an attacker can exploit by eliminating anything that is not required for the system's intended function. A. Phishing is incorrect. Phishing is a social engineering attack technique used to steal credentials — it is an attack, not a defensive practice. B. Social engineering is incorrect. Social engineering refers to manipulating people into revealing information or performing actions — it is an attack category, not a hardening technique. D. Buffer overflow is incorrect. A buffer overflow is a software vulnerability caused by inadequate input validation — it is an attack type, not a security practice.

Q5: 1 = D; 2 = A; 3 = C; 4 = B

The correct mapping is: Identify focuses on inventorying critical assets and data — understanding what the organization has, its value, and its risk exposure. Protect involves restricting unauthorized access through controls such as access management, encryption, and training. Detect covers alerting on anomalies — using tools like SIEM, IDS, and monitoring to identify potential incidents in progress. Respond means containing the impact of incidents — executing response plans to limit damage and restore normal operations. The NIST CSF also includes a fifth function, Recover, focused on restoring capabilities. These five functions provide a complete risk management cycle.

Q6: C

D. Cellular is incorrect because it provides wide-area carrier connectivity to mobile networks, not short-range pairing with nearby peripherals. C. Bluetooth is correct: it is the mobile connection method designed for short-range wireless pairing between devices and nearby peripherals such as headsets, keyboards, and speakers. B. Wi-Fi is incorrect because it provides local network access rather than direct device-to-peripheral pairing. A. Ethernet is incorrect because it is a wired connection method and cannot serve as a wireless pairing technology.

Q7: B

B. CVSS is correct. The Common Vulnerability Scoring System provides a standardized numerical score (0–10) based on metrics like attack vector, complexity, and impact on confidentiality, integrity, and availability, enabling security teams to prioritize which vulnerabilities to remediate first. A. CVE is incorrect. CVE (Common Vulnerabilities and Exposures) is an identifier that names and catalogues vulnerabilities but does not provide a severity or exploitability score. D. CWE is incorrect. CWE (Common Weakness Enumeration) classifies software weaknesses by type but does not score individual vulnerabilities for prioritization. C. NIST score is incorrect. NIST does not define a standalone 'NIST score' for vulnerability prioritization.

Q8: A

A. Correct — an access control vestibule (also called a mantrap) is an automated entry with two interlocking doors where only one door can open at a time, controlling access and preventing tailgating. B. A reception area is a staffed lobby, not a two-door interlocking barrier. C. A waiting room is a general-purpose space with no interlocking-door access control. D. "Vestibule office" is not a physical access control mechanism.

Q9: C

C (XDR collects and correlates data across various network appliances) is correct: extended detection and response widens telemetry beyond the endpoint to email, network, identity and cloud sources and correlates it into a single detection, which is precisely what EDR on its own cannot do. A (XDR is faster than EDR) is incorrect because speed is not the distinguishing property; breadth of correlated telemetry is. B (The agent footprint of XDR is significantly smaller than an agent for EDR) is incorrect because XDR still relies on the same endpoint agents plus extra collectors, so the footprint is equal or larger. D (XDR does not require user input) is incorrect because analysts still tune, triage and respond in both platforms.

Q10: B, D

B and D are correct: disabling unused ports and protocols shrinks the attack surface, and changing default vendor passwords removes well-known credentials that attackers routinely try. E is incorrect: granting all users administrative rights violates least privilege and widens the attack surface. A is incorrect: opening Telnet exposes an unencrypted management protocol and increases risk rather than reducing it. C is incorrect: installing a duplicate copy of the application adds unnecessary software, the opposite of hardening.

Q11: 1 = D; 2 = C; 3 = A; 4 = B

The correct mapping is: Eradication removes the threat from affected systems — deleting malware, closing backdoors, and eliminating the root cause. Containment limits the spread and impact of the incident by isolating compromised systems or network segments. Recovery restores systems to normal operations, verifying they are clean and functional before returning to production. Lessons learned involves reviewing what went well and what failed after the incident is resolved, informing improvements to policies, procedures, and controls. These phases follow the NIST SP 800-61 incident response lifecycle and occur in sequence.

Q12: A

A. Correct: when no single entity owns and controls a library, accountability for secure development and timely patching can be diffuse, which raises supply-chain risk where governance and maintenance are weak. B. Incorrect: open-source projects use the same classes of development tools as commercial software; inferior tooling is not an inherent open-source trait. C. Incorrect: open-source libraries are not unverifiable stubs; their source code is publicly available and can be inspected. D. Incorrect: open-source platforms are operated by legitimate communities and vendors, not by threat actors.

Q13: C

C (Separation of duties) is correct: preventing one employee from both creating an invoice and approving its payment splits a sensitive financial process between two people, which is the classic anti-fraud application of separation of duties. D (Role-based access control) is incorrect because RBAC is only the mechanism that assigns permissions by job role; on its own it would happily place both permissions in one role. B (Discretionary access control) is incorrect because DAC lets the owner of an object grant access at their discretion, which is about who controls a resource, not about conflicting duties. A (Least functionality) is incorrect because it means disabling unneeded services and features on a system, a hardening idea unrelated to who approves payments.

Q14: B, C

B and C are correct: firewall logs show which outbound connections were permitted, to which external address, and how much data crossed, while NetFlow records provide flow metadata such as source, destination, ports, and byte counts without a full packet capture, so together they reconstruct where the data went and how much left. A is incorrect (The most recent vulnerability scan report for the database server) because a scan report lists weaknesses that could be exploited; it records nothing about traffic that actually occurred. D is incorrect (The antivirus signature update log on the server) because it only shows when definitions were downloaded and cannot reveal outbound data transfers. E is incorrect (The password policy audit report for the database accounts) because it describes configuration compliance for credentials, not network activity or data movement.

Q15: A

C. Set the scope is incorrect because the scenario states that scoping has already been completed. D. Determine the sensitivity level is incorrect because sensitivity decisions belong to the planning phase already finished at this point. A. Update the plug-ins is correct: refreshing the scanner's plug-ins immediately before execution ensures the scan can detect the most recently disclosed vulnerabilities. B. Execute the scan is incorrect because running it without updated plug-ins would miss newly published vulnerabilities.

Q16: B

B. Network packet analysis is correct. Packet captures record the actual contents of network communications, so analyzing them lets Sergio examine what was transmitted during the incident. C. Law enforcement data is incorrect. It aggregates external crime statistics and case information; it does not contain the organization's captured network traffic. D. Insurance company data is incorrect. Insurers provide loss and claims statistics useful for risk calculations, not the contents of network communications. A. Data from computer incident monitoring organizations is incorrect. These organizations share incident trends and indicators across companies; they do not hold the packets captured on Sergio's network.

Q17: A

D. EAP-SSL is incorrect. It is not a recognized EAP method; SSL is a deprecated predecessor of TLS, not an EAP variant. C. EAP-TLS is incorrect. EAP-TLS performs mutual certificate-based authentication and requires a digital certificate on every client; it does not carry password- or token-based inner authentication, so it fails the no-client-certificate requirement. A. EAP-TTLS is correct. EAP-TTLS builds a TLS tunnel authenticated by the server's certificate and then carries legacy inner authentication protocols — such as PAP with passwords or one-time-password token codes — inside the protected tunnel, with no client certificate required. B. EAP-FAST is incorrect. EAP-FAST does establish a protected TLS tunnel, but it typically does so with a Protected Access Credential (PAC) rather than a server certificate, and its inner methods are EAP-based; it does not meet the requirement for a server-certificate-authenticated tunnel carrying legacy protocols such as PAP.

Q18: 1 = C; 2 = B; 3 = D; 4 = E; 5 = F

1 → C (Espionage): espionage steals confidential information to gain strategic or competitive intelligence. 2 → B (Service disruption): service disruption makes systems or services unavailable to interrupt operations. 3 → D (Blackmail): blackmail is coercion — the attacker threatens to release stolen data unless demands are met. 4 → E (Financial gain): financial gain is direct profit from stealing money, card data, or credentials that can be sold. 5 → F (Revenge): revenge retaliates against an employer or individual for a perceived wrong. Unused: G (ethical) — responsible, lawful disclosure is an ethical motivation not listed here; A (misinformation) — spreading false information to mislead the public is a separate motivation and vector.

Q19: C

B. Insider threat is incorrect. An insider threat comes from someone within the organization who abuses authorized access; here the actor is an external vendor. A. Privilege escalation is incorrect. Privilege escalation is gaining rights beyond those granted; the scenario describes access through a legitimate trusted connection, not the elevation of privileges. C. Third-party risk is correct. Granting a vendor access through a trusted connection extends the organization's attack surface to that external party, so a compromise of the vendor can reach internal systems - the essence of third-party (supply-chain) risk. D. Data classification failure is incorrect. A classification failure is mislabeling data sensitivity; the issue here is external access, not how data is labeled.

Q20: D

D is correct (A conflict of interest): a conflict of interest exists when a person involved in a decision has a personal or financial relationship that could bias the outcome. The appropriate response is to document the disclosure and remove the lead from scoring so that the selection stays objective and defensible. B is incorrect (A lack of due diligence) because due diligence is the investigation of a vendor's financial stability, security posture, and reputation; the lead's disclosure does not indicate that this research was skipped. C is incorrect (A supply chain dependency) because that describes reliance on upstream suppliers whose failure would affect operations, not a personal relationship influencing a purchasing decision. A is incorrect (A rules-of-engagement violation) because rules of engagement govern the conduct of penetration tests and are unrelated to procurement ethics.

Q21: B

B (SIEM with alerting) is correct: a SIEM ingests authentication and access logs from across the environment, correlates them and fires alerts on patterns such as repeated failed logins, off-hours access or impossible travel, which is what real-time detection of unauthorised attempts requires. C (DLP) is incorrect because data loss prevention watches sensitive data leaving the organisation, not who is trying to log in. D (Endpoint encryption) is incorrect because full disk encryption protects data at rest on a lost device and produces no access alerting. A (Load balancing) is incorrect because distributing sessions across servers serves availability and performance, with no detection role.

Q22: D

D. Integrity is correct. Integrity ensures that data has not been altered — whether accidentally (transmission error) or maliciously (tampering). Controls such as hashing, digital signatures, and file integrity monitoring (FIM) enforce integrity by detecting unauthorized modifications to data in transit or at rest. B. Confidentiality is incorrect. Confidentiality prevents unauthorized disclosure of information. Encryption and access controls are its primary mechanisms — not verifying accuracy or detecting modifications. A. Availability is incorrect. Availability ensures authorized users can access systems and data when needed — supported by redundancy, failover, and backup strategies. C. Non-repudiation is incorrect. Non-repudiation prevents a party from denying an action they performed. While related to integrity, it is a distinct property achieved through digital signatures and audit logs.

Q23: 1 = A; 2 = D; 3 = B; 4 = C

The correct pairings are: Cloud = Scalable resource model via internet; On-premises = Full control of hardware and network; Serverless = Provider handles all backend infrastructure; Hybrid = Mix of local and internet-hosted infrastructure. Cloud (public cloud) provides on-demand, internet-accessible compute and storage managed and scaled by the provider. On-premises means the organization owns and operates all hardware and software, giving maximum control at higher capital cost. Serverless is a cloud execution model where the provider fully manages servers, scaling, and runtime — customers deploy code only, with no server administration. Hybrid combines on-premises infrastructure with cloud resources, allowing workloads to move between environments based on cost, compliance, or performance needs.

Q24: B

A. They require less storage is incorrect. Immutability governs whether data can be changed, not how much space it uses; immutable copies may even consume more storage because they cannot be overwritten. C. They are compressed in real time is incorrect. Compression is a separate storage-efficiency feature and is unrelated to whether a backup can be modified. B. They cannot be altered once written is correct. An immutable backup is write-once/read-many: after it is written it cannot be changed, encrypted, or deleted for a defined retention period, which protects recovery points from ransomware and malicious insiders. D. They allow live editing by admins is incorrect. This is the opposite of immutability - the entire point is that not even administrators can modify the protected copy during its retention window.

Q25: C

A. "Mistranslations" is not a type of attack countered by monitoring look-alike domains. B. "Spimming" (SPIM) is unsolicited spam sent over instant messaging, which is unrelated to registering look-alike domain names. C. Correct — typosquatting (URL hijacking) registers misspelled or look-alike variations of a legitimate domain; researching and claiming those similar domains is how Wolfgang-Cashman counters it. D. "Redactioning" is not a recognized attack type.

Q26: C

B. Mission-essential functions is incorrect because it identifies the critical activities an organization must sustain, a continuity-planning concept, not the post-incident review step. D. Recovery objectives is incorrect because targets such as RTO and RPO define recovery goals; they do not describe documenting and analyzing an incident to improve future response. C. Lessons learned is correct because this final incident-response phase completes the incident documentation, analyzes what happened to strengthen security, and feeds improvements into future responses. A. Tactical summary is incorrect because it is not a defined incident-response phase.

Q27: D

A. Segmentation is incorrect. Network segmentation limits lateral movement between zones but does not directly enforce which specific files a user can open. C. Data tokenization is incorrect. Tokenization replaces sensitive values with surrogates; it does not restrict a user from accessing files in a shared folder. D. Role-based access control is correct. RBAC ensures users receive only the permissions aligned with their job function, so an employee cannot reach files outside their assigned role, directly addressing this scenario. B. Whitelisting is incorrect. Application allowlisting restricts which programs can execute; it does not govern file-level access by user role.

Q28: A

A (Finding linkages from multiple data sources.) is correct: data correlation is the process of connecting related events that come from different sources, so that a pattern no single log would reveal becomes visible. A SIEM performs this correlation with rules and analytics to turn scattered entries into a meaningful security event. B (A requirement for using ML.) is incorrect because machine learning can support correlation, but correlation is not a prerequisite for ML; they are separate concepts. D (A dated technology no longer used...) is incorrect because correlation is the core function of a SIEM, not something SIEM replaced. C (Using a minimum of three external and three internal data sources...) is incorrect because there is no fixed number of sources and correlation applies to all kinds of events, not only zero-day attacks.

Q29: B

D. Host hardening is incorrect. Hardening individual hosts reduces each system's attack surface but does not restrict east-west traffic between peers on a flat network, so lateral movement remains possible. A. Patch management is incorrect. Patching closes known vulnerabilities but does not isolate hosts from one another; an attacker with valid credentials or an unpatched path can still move laterally. B. Microsegmentation is correct. Microsegmentation enforces granular policy between workloads, so even within one broadcast domain a compromised host cannot freely reach its neighbors — directly limiting lateral movement. C. NAT is incorrect. Network Address Translation remaps addresses at a boundary; it provides no internal segmentation and does not stop movement between hosts on the same flat network.

Q30: A

C. NFC capture attack is incorrect. NFC capture refers to intercepting near-field communication at very close range and is not the standard term for rogue AP-based wireless interception. A. Evil twin attack is correct. An evil twin sets up a rogue access point that mimics a legitimate one, luring users to connect so the attacker can intercept and capture their wireless transmissions in a man-in-the-middle position. D. WPA grab attack is incorrect. This is not an established attack category; it does not describe a mechanism for capturing user transmissions via a rogue AP. B. Sleeper attack is incorrect. A sleeper attack refers to malware or an agent that remains dormant before activating — not a wireless interception technique.

Q31: D

C. An attacker can steal data from any folder with file sharing enabled is incorrect as a reason — it IS a genuine risk of default configurations that enable file sharing, so Zendaya would mention this. D. Wireless devices could be susceptible to an INKSPOT attack is correct (as the NOT answer). INKSPOT is not a recognized wireless security threat, so Zendaya would not cite it as a real risk — making it the item she would NOT mention. B. User names, passwords, and credit card numbers could be captured is incorrect as a reason — this is a real risk of unencrypted WLANs, so she would mention it. A. Malware can be injected into a computer connected to the WLAN is incorrect as a reason — drive-by malware delivery over unsecured Wi-Fi is a documented threat she would warn about.

Q32: A

D. MAC is incorrect. Mandatory Access Control uses classification labels enforced system-wide; it does not evaluate dynamic attributes like time of day or location. C. RBAC is incorrect. Role-Based Access Control grants access based purely on assigned roles and does not natively incorporate contextual attributes. A. ABAC is correct. Attribute-Based Access Control evaluates attributes of the subject (department), resource, and environment (time of day, location) at the moment of access, enabling fine-grained, context-aware decisions. B. DAC is incorrect. Discretionary Access Control delegates decisions to resource owners; it does not rely on multiple dynamic attributes.

Q33: C

C (Software keyloggers are generally easy to detect.) is correct: the question asks for the statement that is NOT true, and this one is false. Software keyloggers are designed to hide, often disguising themselves as legitimate processes or using rootkit techniques, so they are generally difficult to detect. B (Software keyloggers can be designed to send captured information...) is incorrect as an answer because transmitting the captured keystrokes to the attacker over the Internet is a typical feature of software keyloggers. A (Hardware keyloggers are installed between the keyboard connector...) is incorrect as an answer because a hardware keylogger is a device inserted between the keyboard cable and the computer's port. D (Keyloggers can be used to capture passwords, credit card numbers...) is incorrect as an answer because harvesting such sensitive data is the purpose of a keylogger.

Q34: B

A. Tracking software is incorrect because recording the user's activity is core surveillance functionality that spyware performs after it is installed. D. System-modifying software is incorrect because changing system or browser settings is a post-installation behavior spyware uses to embed and persist. C. Active tracking technologies is incorrect because techniques such as keystroke logging and screen capture actively monitor the victim once the spyware is running. B. Automatic download of software is correct: automatic or drive-by downloads are the delivery vehicle that gets spyware onto the machine in the first place, a distribution method rather than a capability the spyware exercises afterward.

Q35: C

D. BPA is incorrect. A business partners agreement is a binding contract defining each partner’s obligations, contributions, and share of profits or losses. B. SLA is incorrect. A service-level agreement is a contractual, enforceable commitment to measurable service levels, often with penalties for missing them. C. MOU is correct. A memorandum of understanding documents a mutual understanding and intent between parties and is generally not intended to create legally binding obligations, while still being more formal than a verbal agreement. A. MSA is incorrect. A master service agreement is a binding contract establishing the general terms that govern current and future work between the parties.

Q36: C

D. Security training is incorrect because training encourages good password habits but cannot technically stop a user from choosing a weak password. C. Password complexity policies is correct because complexity requirements are enforced at password creation, automatically rejecting passwords that are too short or too simple. B. Biometric authentication is incorrect because it adds or replaces an authentication factor; it does nothing to prevent weak passwords from being created where passwords are still in use. A. Application firewall is incorrect because it filters traffic to applications and plays no role in password creation.

Q37: C

C (It uses strictly automatic processes.) is correct: the question asks what Alois would NOT say, and this statement is false. A security operations center combines people, processes, and technology; orchestration tools may filter basic alerts, but tiered human analysts triage alerts, investigate incidents, hunt threats, and decide on response, so a SOC is never strictly automatic. D (It houses the IT security team.) is incorrect as an answer because the SOC is the centralized hub where the security analysts work. B (It is responsible for detecting and analyzing cybersecurity incidents.) is incorrect as an answer because monitoring, detecting, and analyzing incidents in real time is the primary function of a SOC. A (A SOC responds to cybersecurity incidents.) is incorrect as an answer because coordinating rapid response and remediation is one of the SOC's key objectives.

Q38: 1 = C; 2 = B; 3 = A; 4 = D

The correct mapping is: Policy is a high-level rule that guides organizational decision-making (e.g., 'all sensitive data must be encrypted'). Standard is a mandatory, detailed technical requirement that supports a policy (e.g., 'AES-256 must be used'). Guideline is an optional recommended practice — it offers advice but is not enforceable. Procedure is a step-by-step action plan describing exactly how a task must be performed. These four terms form a hierarchy: policies set intent, standards enforce specifics, guidelines advise, and procedures operationalize.

Q39: A

C. Physical is incorrect. Physical controls protect the physical environment (locks, fences, guards); applying an encryption algorithm to backups is not a physical measure. D. Administrative is incorrect. Administrative (managerial) controls are policies, procedures, and training — not the technology that performs the encryption. A. Technical is correct. AES-256 is implemented through technology (software/hardware that encrypts the data), which makes it a technical (logical) control safeguarding the backups' confidentiality. B. Compensating is incorrect. A compensating control substitutes for a primary control that cannot be used; here encryption is a direct primary control, not a substitute for one.

Q40: 1 = B; 2 = D; 3 = C; 4 = A

The correct pairings are: Risk avoidance = Not launching a project due to potential risk; Risk acceptance = Choosing to do nothing after risk evaluation; Risk mitigation = Applying a patch to remove vulnerability; Risk transference = Buying cyber insurance. Risk avoidance eliminates the risk by deciding not to engage in the activity that creates it — declining to launch a product because its security risks are unacceptable is the classic example. Risk acceptance is a conscious decision to tolerate a known risk without additional controls, typically because mitigation cost exceeds potential loss. Risk mitigation reduces the probability or impact of a risk through controls such as patching, MFA, or network segmentation. Risk transference moves the financial consequence to a third party — most commonly through cyber liability insurance policies.

Q41: 1 = D; 2 = C; 3 = A; 4 = B

The correct mapping is: Syslog standardizes the format for remote log collection, providing a universal protocol for devices to send log messages to a centralized server over UDP (port 514) or TCP. Immutable logs prevent tampering after capture — once written, they cannot be altered, deleted, or overwritten, making them critical for forensic integrity. Log aggregation provides centralized analysis and storage, collecting logs from disparate sources into one platform for correlation and searching. Chain of custody preserves evidence integrity by documenting every person who handled evidence, when, and what was done — essential for legal admissibility in investigations.

Q42: 1 = D; 2 = A; 3 = C; 4 = B

COBIT pairs with "IT governance and process management" because ISACA's COBIT framework provides governance objectives that align IT with business goals. ISO/IEC 27001 pairs with "Information security management systems" because it defines the requirements to establish, operate, and continually improve an ISMS. NIST SP 800-53 pairs with "Security control catalog for federal systems," offering a comprehensive catalog of security and privacy controls for U.S. federal information systems. CIS Controls pairs with "Baseline technical controls," providing a prioritized set of actionable technical safeguards that organizations can implement to defend against common attacks.

Q43: B

B (SSRF) is correct: server-side request forgery abuses the trust one server places in another, tricking a vulnerable server into issuing requests on the attacker's behalf to internal or external systems the attacker cannot reach directly. C (CSRF) is incorrect because cross-site request forgery abuses the trust a site places in the user's browser and session, riding an authenticated user's cookies rather than a server-to-server relationship. D (EXMAL) is incorrect because it is not a real attack acronym. A (SCSI) is incorrect because Small Computer System Interface is a storage bus standard for disks and tape drives, not an attack of any kind.

Q44: B

D. Obfuscation is incorrect because it only makes code harder to read; it does not check untrusted input. A. Code signing is incorrect because it proves the integrity and origin of code, not the safety of user-supplied data. B. Input validation is correct: checking untrusted user-supplied data against expected formats before it is processed reduces the risk of cross-site scripting (XSS). C. Normalization is incorrect because converting data to a canonical form supports validation but does not by itself check or reject malicious input.

Q45: D

D (Simulate response to a security incident) is correct: a tabletop exercise walks the response team through a hypothetical scenario in discussion form, testing the plan, clarifying who does what, and surfacing gaps before a real incident happens. A (Perform root cause analysis) is incorrect because root cause analysis examines an incident that has actually occurred and belongs to the lessons learned phase. B (Conduct red team evaluation) is incorrect because a red team mounts a live adversarial attack against real systems, while a tabletop executes nothing. C (Test DLP policies in production) is incorrect because validating data loss prevention rules is a hands-on technical test of one control.

Q46: C

B. Forensic imaging is incorrect. Forensic imaging creates a preserved evidentiary copy of storage media — it is an investigation technique, not the phase defined by stopping an attack's spread. A. Playbook execution is incorrect. Playbook execution describes the method of following predefined IR procedures — it is not a named phase in the incident response lifecycle. C. Containment is correct. The containment phase focuses on isolating affected systems to prevent the attack from spreading further while the investigation continues. Actions include disconnecting infected hosts from the network, blocking malicious IP addresses, and disabling compromised accounts — all aimed at limiting damage without destroying evidence. D. Threat hunting is incorrect. Threat hunting is a proactive pre-incident activity; by definition, it occurs before an incident is confirmed, not after a compromise has been detected.

Q47: C

B. To encrypt data during transmission is incorrect. Encryption provides confidentiality and is reversible with a key; hashing is one-way and does not conceal data for transport. D. To compress large files is incorrect. A hash produces a fixed-length digest regardless of input size and cannot be reversed to reconstruct the file, so it is not compression. C. To verify data integrity is correct. Hashing produces a fixed-length digest that changes if the input changes, so comparing hashes confirms whether data has been altered; its primary use is integrity verification. A. To authenticate user credentials is incorrect. Hashing is used when storing passwords, but on its own the function of hashing is integrity, not the authentication decision itself.

Q48: 1 = A; 2 = C; 3 = B; 4 = D

The correct pairings are: Hashing = Ensures integrity with a fixed-length output; Symmetric encryption = Encrypts using a shared secret key; Asymmetric encryption = Uses a key pair for secure data exchange; Digital signature = Provides authentication and non-repudiation. Hashing algorithms (SHA-256, SHA-3) produce a fixed-length digest — any change to the input produces a different digest, making hashing ideal for integrity verification. Symmetric encryption (AES, 3DES) uses the same key for encryption and decryption — fast but requires secure key distribution. Asymmetric encryption (RSA, ECC) uses a mathematically linked public/private key pair for secure key exchange and encryption. A digital signature applies the sender's private key to a hash of the message — recipients verify using the public key, proving both authenticity and non-repudiation.

Q49: 1 = B; 2 = D; 3 = C; 4 = A

The correct pairings are: Containment = Disconnect affected systems; Identification = Analyze logs for signs of compromise; Preparation = Define roles and responsibilities; Eradication = Scan for malware and clean systems. Preparation is completed before any incident — it involves creating IR plans, assigning roles, and provisioning tools. Identification (detection and analysis) involves reviewing logs, alerts, and artifacts to confirm and characterize a security event. Containment limits the spread by isolating affected systems from the network. Eradication removes the root cause — deleting malware, closing backdoors, and revoking compromised credentials so the threat cannot persist.

Q50: C

C (MITB) is correct: a man-in-the-browser attack plants malware, typically a malicious extension or injected code, between the browser and the underlying operating system so it can read and silently alter transactions after the user has already authenticated. B (MITM) is incorrect because a man-in-the-middle attack intercepts traffic between two endpoints on the network path, not inside the host between browser and OS. D (MRTR) is incorrect because it is not a recognised attack or security acronym. A (MTTR) is incorrect because mean time to repair is an availability metric used in resilience and incident-response planning, not an attack at all.

Q51: 1 = B; 2 = D; 3 = E; 4 = A

1 → B (Removable device): a USB drive dropped in a parking lot relies on someone plugging in physical media. 2 → D (Message-based email or file): a malicious macro inside an emailed invoice arrives through a message and file vector. 3 → E (Supply chain): a tampered driver update from a trusted vendor is a supply chain compromise. 4 → A (Image-based): a malicious QR code sticker delivers its payload through an image the victim scans. Unused: F (default credentials) — no unchanged factory password is involved; C (open service port) — no exposed listening service is used in these scenarios.

Q52: B

D. Vulnerability scanning is incorrect. Vulnerability scanning is an active process of probing systems for known weaknesses using tools like Nessus or Qualys — it is a security assessment activity, not a traffic-filtering network device. A. Threat hunting is incorrect. Threat hunting is a proactive analyst-led activity searching for adversaries in the environment — it is not a network appliance. C. Playbook execution is incorrect. A playbook is a documented set of incident response procedures — it is a process guide, not a security device placed in the network path. B. Firewall is correct. A firewall is a network security device (hardware or software) positioned between internal networks and external connections. It inspects traffic and permits or denies it based on configured rules. Stateful firewalls track connection state; next-generation firewalls add application awareness, deep packet inspection, and integrated threat intelligence.

Q53: D

D. Base score is correct. In CVSS, the Base metrics represent the intrinsic characteristics of a vulnerability, including Confidentiality, Integrity, and Availability impact sub-metrics, producing a severity score that does not change with time or environment. A. Gap analysis is incorrect. A gap analysis compares current state to desired state; it is not part of CVSS. B. Zero trust is incorrect. Zero trust is a security architecture philosophy, unrelated to CVSS scoring. C. Non-repudiation is incorrect. Non-repudiation is a cryptographic property ensuring actions cannot be denied, not a vulnerability scoring metric.

Q54: C

B. OWE is incorrect because Opportunistic Wireless Encryption encrypts traffic on open networks that use no password at all, so it plays no role in protecting a password from guessing attacks. C. SAE is correct: Simultaneous Authentication of Equals replaces WPA2-style pre-shared-key authentication with a password-authenticated key exchange (Dragonfly), so a captured exchange cannot be used for offline password guessing and each session derives fresh keying material. A. XR3 is incorrect because it is not a real WPA3 technology or wireless security standard. D. PMF is incorrect because Protected Management Frames defend against forged management frames such as deauthentication attacks; they do not protect the password exchange.

Q55: C > D > A > B

The correct vulnerability management lifecycle order is: Discovery first — scanning the environment to identify assets and potential vulnerabilities. Then Assessment — analyzing discovered vulnerabilities to understand their severity, exploitability, and risk. Then Remediation — applying patches, configuration changes, or mitigations to address identified weaknesses. Finally Verification — re-scanning or testing to confirm that remediation was successful and the vulnerability no longer exists. Skipping or reordering steps (e.g., remediating before assessing severity) leads to wasted effort and unresolved risk.

Q56: C

A. Injecting code into a website is incorrect. That describes injection attacks such as XSS or SQL injection, not interception of a conversation. C. Intercepting communication between two parties is correct. In a man-in-the-middle attack the adversary secretly positions itself between two communicating endpoints, relaying and possibly altering traffic while both sides believe they talk directly to each other (for example via ARP spoofing or a rogue access point). B. Using a fake login page to steal credentials is incorrect. That describes phishing or credential harvesting, which tricks a user rather than intercepting an existing session. D. Escalating local privileges is incorrect. Privilege escalation raises an attacker's rights on a system already accessed; it is unrelated to intercepting communications.

Q57: A

B. Compression errors introduced during transfer is incorrect: compression is unrelated to the confidentiality risk of clear-text transmission. D. Repeated authentication failures at the gateway is incorrect: the absence of encryption does not by itself cause authentication attempts to fail. A. Data interception by unauthorized parties is correct: PII sent over an unencrypted protocol travels in clear text and can be captured by anyone eavesdropping on the network path. C. Higher CPU load on the sending and receiving hosts is incorrect: skipping encryption actually reduces processing overhead, so CPU load is not the concern.

Q58: A

C. Vulnerability scanning is incorrect as the exception because it is a primary identification method used to find known weaknesses in systems. D. Penetration testing is incorrect because simulated attacks are a listed way to identify vulnerabilities that automated scanners can miss. B. Responsible disclosure program is incorrect because such programs, including bug bounties, let external researchers report vulnerabilities and are part of identification. A. Data retention is correct: it is a data lifecycle and disposal/decommissioning consideration within asset management, not a vulnerability management activity.

Q59: A

B. GDPR is incorrect: it protects the personal data of individuals in the EU, not U.S. health records specifically. D. PCI DSS is incorrect: it governs payment card data, not medical records. A. HIPAA is correct: the Health Insurance Portability and Accountability Act governs the privacy and security of protected health information for U.S. patients. C. FISMA is incorrect: it applies to U.S. federal agency information systems, not private health records generally.

Q60: C

A. Determine regulatory and contractual compliance obligations is incorrect. Identifying legal and contractual obligations is part of governance and compliance programs, not the purpose of a BIA. D. Catalogue third-party vendors and their contract terms is incorrect. Building an inventory of suppliers and the terms they are held to is vendor and third-party risk management; the BIA consumes that inventory when it assesses impact but does not exist to produce it. C. Identify critical business functions and dependencies is correct. A BIA determines which business functions are most critical, the resources and dependencies they rely on, and the impact of their disruption over time - feeding recovery priorities and values such as RTO and RPO. B. Plan incident response and escalation procedures is incorrect. Building IR and escalation procedures is a separate activity; the BIA informs continuity and recovery planning but does not itself define incident response steps.

Q61: D

A. Frequent account lockouts for legitimate users is incorrect: lockouts result from exceeding failed login thresholds, not from leaving default credentials in place. C. Authentication fatigue from repeated MFA prompts is incorrect: that describes users approving repeated push notifications until one is accepted, which is unrelated to default credentials. D. Unauthorized access from known exploits is correct: default vendor usernames and passwords are publicly documented, so attackers can look them up and log in directly if they are not changed. B. Loss of the encryption keys held in escrow is incorrect: key loss is a key-management and escrow issue, not a consequence of default credentials.

Q62: D

C. To improve application response times under peak user load is incorrect. Configuration baselines define approved secure settings; any performance effect is incidental and is not their purpose. B. To give end users more freedom to change system settings is incorrect, and in fact reversed: baselines constrain configurations to an approved standard, reducing rather than increasing user discretion. D. To establish secure and standardized system settings is correct. A configuration baseline defines the approved, hardened configuration for a device or application type (for example CIS Benchmarks or DISA STIGs), and tooling compares running systems against it so configuration drift can be detected and corrected. A. To prevent data loss during unplanned system failures is incorrect. Surviving a hardware or system failure without losing data depends on backups, replication and redundancy; a baseline standardizes how a system is configured and does not protect the data it holds.

Q63: D

D (Defense in depth) is correct: it is a layered security strategy in which multiple overlapping controls protect the same asset, so that if one layer fails the next one still stops the attacker. B (Least privilege) is incorrect because it is a single access principle about granting accounts only the minimum rights they need, not about stacking layers of protection. C (Social engineering) is incorrect because it is an attack technique that manipulates people into breaking procedure; it is a threat, not a protective method. A (Tokenization) is incorrect because it is one data-protection technique that swaps sensitive values for non-sensitive tokens, a single control rather than a multi-layer strategy.

Q64: B

D. "Organizations can enrich their own existing information and make it more actionable" is a genuine advantage of sharing, so it is not the answer. A. "Organizations can independently confirm their own observations with other sharing members and improve overall quality by reducing ambiguity and errors" is a genuine advantage, so it is not the answer. C. "Organizations can leverage the collective knowledge, experience, and capabilities of the sharing community for a more complete understanding of threats" is a genuine advantage, so it is not the answer. B. "Organizations can identify third-party OSINT providers more quickly to purchase their threat feeds" is correct because it is NOT an advantage of sharing threat intelligence: locating vendors to buy feeds from is unrelated to the value that comes from members exchanging and corroborating threat data.

Q65: B

B. Expansionary is correct: an expansionary risk appetite means the organization is willing to take on more risk in pursuit of growth and new opportunities. C. Conservative is incorrect: a conservative risk appetite favors minimizing risk, accepting lower returns or slower growth in exchange for greater safety. A. Neutral is incorrect: a neutral risk appetite balances risk-taking and caution rather than favoring growth-driven risk. D. Restrictive is incorrect: it is not one of the risk appetite types in the SY0-701 objectives, which list expansionary, conservative, and neutral.

Q66: D

D is correct (Tune the rule to exclude the misconfigured service account): alert tuning is the remedy for alert fatigue. Because the noise has a confirmed benign cause, the rule should be refined to filter that account while the scheduled job is fixed, keeping a threshold that still catches brute-force patterns, so analysts trust the queue again. B is incorrect (disable the failed-login correlation rule) because switching the rule off blinds the SOC to real brute-force attempts. A is incorrect (quarantine every host) because quarantine answers a confirmed threat; this is a known misconfiguration, so isolating hosts would disrupt production for no gain. C is incorrect (shorten the log retention period) because retention governs how long logs are stored for compliance and forensics, not how many new events match the rule each day.

Q67: D

B. Ransomware is incorrect. Ransomware encrypts files or systems and demands payment; the defining trait here is disguise as a legitimate tool, not extortion. C. Adware is incorrect. Adware displays or injects unwanted advertising; it does not centrally describe software masquerading as a legitimate application to gain installation. D. Trojan is correct. A Trojan is malware disguised as a legitimate or desirable program, relying on the user to install it voluntarily — exactly the scenario described. A. Rootkit is incorrect. A rootkit hides its presence and maintains privileged persistence on a system; concealment after compromise is its hallmark, not the initial deception used to get installed.

Q68: B

C. Reduces insurance premiums is incorrect. While robust security practices may influence insurance costs, asset inventory itself does not directly reduce premiums — this is a secondary, indirect benefit. D. Prevents phishing attacks is incorrect. Asset inventory does not stop phishing — that requires email filtering, user training, and anti-phishing controls. B. Identifies unmanaged or vulnerable devices is correct. An asset inventory provides visibility into every device on the network, including shadow IT, unpatched systems, and devices not enrolled in endpoint management — enabling the security team to address vulnerabilities that would otherwise be invisible. A. Speeds up application development is incorrect. Asset inventory is a security and operations function — it has no direct relationship to development velocity.

Q69: C

C. Technical and preventive is correct because the control is implemented through technology (endpoint security software) and it stops unauthorized USB data transfers before they occur. A. Managerial and detective is incorrect because managerial controls govern policy and oversight, and detective controls identify events rather than block them. D. Operational and corrective is incorrect because operational controls are carried out primarily by people and processes, and corrective controls remediate damage after an incident. B. Physical and deterrent is incorrect because physical controls rely on tangible barriers, and deterrent controls merely discourage attackers instead of technically blocking the action.

Q70: A

A. Correct — this statement is NOT accurate: with proper remediation and recovery procedures, such as restoring from clean backups or rebuilding, an infected device can often be returned to normal operation. B. Encrypting data and making resources inaccessible is core ransomware behavior, so this statement is accurate. C. Ransomware can take critical systems offline and halt business processes, so this statement is accurate. D. Phishing emails and other message-based vectors are among the most common ransomware delivery methods, so this statement is accurate.

Q71: D > C > F > A > E > B

Correct order: 1. Generate a public/private key pair — the private key stays secret while the public key will be certified. 2. Create a certificate signing request containing the public key — the CSR carries the public key and identifying details. 3. Submit the CSR to the certificate authority — the request goes to the CA for processing. 4. The CA validates the requester's identity — the CA or its registration authority confirms who is asking. 5. The CA issues the signed digital certificate — the CA binds the identity to the public key with its signature. 6. Install the certificate on the server — the server can now present the trusted certificate to clients.

Q72: 1 = D; 2 = C; 3 = A; 4 = B

The correct mapping is: Brute-force attacks target authentication systems — systematically attempting password combinations until the correct one is found. Cross-site scripting (XSS) targets web browser sessions — injecting malicious scripts into trusted web pages that execute in victims' browsers, stealing session tokens or credentials. ARP spoofing targets LAN devices — the attacker sends fake ARP replies to associate their MAC address with a legitimate IP, enabling man-in-the-middle attacks on local network traffic. Phishing targets email recipients — crafting deceptive messages to trick users into revealing credentials or clicking malicious links. Each attack exploits a fundamentally different layer or communication channel.

Q73: 1 = A; 2 = B; 3 = D; 4 = C

HTTPS matches "Encrypt web-based communications" because it wraps HTTP traffic inside TLS, providing confidentiality and integrity for browser-to-server exchanges. SFTP matches "Provide encrypted file transfer" since SFTP runs file transfer operations over an SSH tunnel on port 22. SNMPv3 matches "Secure monitoring of network devices" because it adds authentication and encryption to SNMP-based management, unlike v1 and v2c which are cleartext. TLS matches "Add confidentiality to legacy apps," because TLS can be used as a generic transport wrapper to protect traffic from protocols that do not have built-in encryption (e.g., via TLS-enabled SMTP, LDAPS, FTPS, or stunnel wrappers).

Q74: B > D > A > E > C

Correct order: 1. A subject requests access to a resource — the flow begins with the user or system asking for access. 2. The policy enforcement point intercepts the request — the PEP stops the request rather than allowing implicit trust. 3. The policy engine evaluates identity, device posture, and context — the engine makes the access decision. 4. The policy administrator issues or denies session credentials based on the decision — it carries the decision out. 5. The enforcement point grants access and the session is logged — access is allowed only after verification, and activity is recorded.

Q75: D

D. Write blocker is correct. A write blocker sits between the investigator's system and the source drive and permits read-only access, preventing any write from altering the original media during acquisition. This preserves evidence integrity and keeps the forensic hash of the copy identical to the source. A. Firewall rule is incorrect. Firewall rules filter network traffic; they play no role in preserving the state of acquired storage media. B. Tokenization is incorrect. Tokenization substitutes sensitive values with non-sensitive references to protect data in use; it is not an acquisition-integrity control. C. EDR alert is incorrect. An endpoint detection and response alert flags suspicious activity but does nothing to guarantee that acquired evidence remains unmodified.

Q76: D

C. Packet sniffer is incorrect. A packet sniffer captures raw network traffic but requires manual analysis to identify behavioral patterns — it lacks the analytical intelligence to automatically detect unusual connection patterns across many hosts. B. SIEM is incorrect. A SIEM correlates log data and generates alerts but focuses on events rather than per-user or per-host behavioral baselines — it is less targeted at behavioral anomalies in outbound connections. A. IDS is incorrect. An IDS detects known attack signatures or statistical anomalies but is not specifically designed to profile individual host behavior over time. D. UEBA is correct. User and Entity Behavior Analytics builds baseline behavioral profiles for users and hosts, then detects deviations — such as unusual outbound connections at atypical times or to unusual destinations — that suggest compromise, insider threat, or data exfiltration.

Q77: A

C. Compliance is incorrect: it describes adherence to laws and standards, not a category of data itself. A. Financial information is correct: it is a recognized data type that organizations classify and protect, alongside types such as regulated data, trade secrets, intellectual property, and legal information. D. Tactical is incorrect: it describes a planning or intelligence level, not a data type. B. Strategic is incorrect for the same reason: it characterizes planning horizons, not a category of data.

Q78: B

A. RPO (Recovery Point Objective) is incorrect. RPO defines the maximum acceptable amount of data loss measured in time (how far back you must be able to recover), not the acceptable downtime. C. MTBF (Mean Time Between Failures) is incorrect. MTBF is a reliability metric estimating the average time between failures of a system, not a target for tolerable downtime. D. MTTR (Mean Time To Repair) is incorrect. MTTR is the average time actually taken to repair a failed component; it is a measured value, not the defined acceptable-downtime objective. B. RTO (Recovery Time Objective) is correct. RTO specifies the maximum acceptable length of time a system or application can be down before it must be restored, making it the metric that defines acceptable downtime.

Q79: A

D. Risk mitigation is incorrect. Mitigation applies a control to reduce likelihood or impact, but here the manager deliberately applies no fix. B. Risk transfer is incorrect. Transfer moves the impact to a third party (for example, insurance); the organization keeps the risk itself in this scenario. C. Risk avoidance is incorrect. Avoidance would mean discontinuing the activity to eliminate the risk entirely, which is not what happens here. A. Risk acceptance is correct. Judging exploitation unlikely and the fix too costly, the manager knowingly chooses to leave the issue unpatched and live with the residual risk - the definition of accepting a risk.

Q80: C

D. To define remote access and VPN client configuration standards is incorrect. Remote access settings and VPN client requirements are specified in a remote access policy and its technical standards, not in an AUP. C. To outline responsible use of organizational resources is correct. An Acceptable Use Policy defines how employees may and may not use organizational systems, networks, and data, setting expectations for appropriate conduct. A. To assign risk ratings to information systems is incorrect. Assigning risk ratings is part of risk assessment and system categorization, not the purpose of an AUP. B. To verify endpoint health before network access is incorrect. Checking device posture before admission is performed by NAC or endpoint compliance tooling, not by an AUP.

Q81: A

D. DNS query log is incorrect. DNS query logs record domain name lookups and are useful for tracking command-and-control or data-exfiltration domains, not for tracing how a specific user account was used. A. Authentication log is correct. Investigating account misuse centers on who logged in, when, from where, and whether attempts succeeded or failed - exactly the events (logons, logoffs, failed authentications, privilege use) captured in authentication logs. C. Network flow log is incorrect. Flow logs summarize traffic between hosts (addresses, ports, volume) but do not tie activity to a user account's authentication events. B. Email delivery log is incorrect. Email delivery logs track message routing and delivery status, which is unrelated to how an account was authenticated or misused.

Q82: B

A. A certificate authority (CA) issues and signs certificates; it is not itself the public directory used to view certificate status. B. Correct — a certificate repository (CR) is a publicly accessible, centralized directory of digital certificates that can be used to view their status. C. "CB" is not a recognized term for a certificate directory. D. "CX" is not a recognized term for a certificate directory.

Q83: A

A is correct (Just-in-time elevation using ephemeral credentials from a PAM vault): privileged access management tools grant elevated rights only for an approved task and issue short-lived credentials that expire when the session ends, removing standing privileges and shrinking the window an attacker could use. C is incorrect (shared administrator account with 90-day expiration) because a shared account is a standing privilege that destroys accountability, and its credential stays usable for months. B is incorrect (permanent domain administrators membership with MFA) because MFA hardens the login, but the privilege is always present, so a hijacked session or an insider holds domain rights around the clock. D is incorrect (role-based access control with time-of-day restrictions) because the role still carries standing rights during the allowed hours and the credentials never expire.

Q84: B

C. NDA is incorrect: a non-disclosure agreement protects confidential information exchanged between the parties and does not define service levels. A. MOU is incorrect: a memorandum of understanding records a general, often non-binding, mutual intent and does not set measurable performance targets. B. SLA is correct: a service-level agreement defines measurable service requirements such as response times, availability, and performance targets that the provider must meet. D. AUP is incorrect: an acceptable use policy governs how users may use organizational systems, not a third party's service commitments.

Q85: B

B (Logic bomb) is correct: a logic bomb is malicious code planted inside a system that stays inert until a trigger fires, such as a date, a specific event, or an account disappearing from the payroll file, and only then deletes data or corrupts systems. D (Worm) is incorrect because a worm is defined by self-replication and autonomous spread across networks, acting immediately rather than waiting on a condition. C (Rootkit) is incorrect because a rootkit works continuously to hide an attacker's presence and maintain privileged access, rather than lying dormant. A (Dropper) is incorrect because a dropper is the delivery component that installs or downloads its payload as soon as it runs.

Q86: A

A. Digital signature is correct: Bob signs the message with his private key, so Alice can verify with Bob's public key that this specific message originated from Bob and was not altered, which also supports non-repudiation. D. 'Encrypted signature' is incorrect because it is not a standard cryptographic mechanism. C. A digest is incorrect because a hash alone proves only integrity; anyone could compute it, so it says nothing about who sent the message. B. A digital certificate is incorrect because it only binds Bob's identity to his public key; by itself it provides no evidence about who created or sent a particular message.

Q87: 1 = B; 2 = A; 3 = D; 4 = C

SQL injection pairs with "Extract data from backend databases" because malicious input manipulates SQL queries to read, modify, or exfiltrate database content. Cross-site scripting pairs with "Inject code into a browser session" since XSS places attacker-controlled scripts into a trusted page, running them in the victim's browser to steal cookies or perform actions. Directory traversal pairs with "Gain unauthorized access to file system paths" because it uses sequences like ../ to escape the intended web root and read arbitrary server files. Clickjacking pairs with "Redirect users into clicking hidden UI elements," tricking users with transparent overlays so their clicks are captured by an attacker-controlled element.

Q88: B

B (Risk register) is correct: the risk register is the living document that lists every known risk together with its likelihood, impact, owner, current status, treatment plan, and residual risk. Because it records both the risks and how each one will be handled, it is the artifact the blank describes. D (Risk matrix) is incorrect because a matrix, or heat map, is a visual grid that plots likelihood against impact for prioritization; it does not record treatment plans. A (Risk assessment report) is incorrect because an assessment report presents the findings of a single evaluation at a point in time, whereas the register is the ongoing inventory maintained across assessments. C (Business impact analysis) is incorrect because a BIA identifies critical business functions and defines metrics such as RTO and RPO; it feeds risk decisions but is not the list of risks and their treatments.

Q89: B

A. Security awareness training is incorrect. Training educates users about threats and policies but does not formally verify compliance with laws or controls. D. Policy review is incorrect. A policy review evaluates policy content and relevance, but it does not assess actual operational adherence to laws and regulations. C. Risk assessment is incorrect. A risk assessment identifies and rates threats and vulnerabilities; it is not the formal mechanism for verifying compliance. B. Compliance audit is correct. A compliance audit is a formal, evidence-based examination conducted to verify that an organization's controls, processes, and records meet legal, regulatory, and internal policy requirements.

Q90: B > E > D > C > A

Correct order: 1. Define the assessment scope and the control objectives the organization must meet — a gap analysis is measured against a stated target, so the systems in scope and the controls that apply are fixed first. 2. Review policies, configurations, and interview technical staff to document the current state — evidence gathering establishes what the organization actually does, as opposed to what its documents claim. 3. Identify where current practice falls short of the required controls — the gaps emerge from comparing the documented current state against the control objectives, so they cannot be listed before either exists. 4. Remediate the shortfalls, prioritizing them by risk — limited resources go to the gaps with the greatest exposure, which is why the gap list has to come first. 5. Undergo the independent third-party audit and receive the certification decision — the external audit is scheduled last, because a gap analysis is run before a formal audit precisely to close weaknesses and avoid surprises in front of the assessor.